

Data Retention & Disposal Policy V2.1

Organization: Company A - Saudi Healthcare Authority
Document ID: DOP-RET-001
Version: 2.1
Classification: INTERNAL
Date: July 1, 2024
Total Pages: 26
Status: APPROVED

DOCUMENT CONTROL

Version	Date	Author	Changes	Approver
1.0	March 20, 2021	Legal Department	Initial policy creation	Dr. Khalid Al-Otaibi
1.5	September 15, 2022	Nora Al-Shamsi	Added PDPL retention requirements	Legal Counsel
2.0	January 10, 2024	Hassan Al-Ghamdi	Enhanced disposal procedures	Dr. Khalid Al-Otaibi
2.1	July 1, 2024	Hassan Al-Ghamdi	Updated healthcare retention periods	Legal Counsel

Document Owner: Legal Department & Data Management Office
Review Cycle: Annual (Next Review: July 2025)
Distribution: All Departments, IT Operations, Legal, Compliance

APPROVAL SIGNATURES

Role	Name	Signature	Date
Chief Data Officer	Dr. Khalid Al-Otaibi	[Signed]	July 1, 2024
General Counsel	Dr. Abdullah Al-Rasheed	[Signed]	June 30, 2024
Chief Compliance Officer	Fatima Al-Harbi	[Signed]	June 29, 2024
IT Operations Director	Mohammed Al-Zahrani	[Signed]	June 28, 2024

TABLE OF CONTENTS

1. POLICY PURPOSE AND SCOPE	4
2. LEGAL & REGULATORY BASIS	6
3. RETENTION SCHEDULE (DETAILED)	9
4. LITIGATION HOLD PROCEDURES	16
5. SECURE DISPOSAL METHODS	19
6. AUDIT & ENFORCEMENT	23
7. ROLES AND RESPONSIBILITIES	25
APPENDIX A: RETENTION SCHEDULE QUICK REFERENCE	26
APPENDIX B: CERTIFICATE OF DESTRUCTION TEMPLATE	27

1. POLICY PURPOSE AND SCOPE

1.1 Purpose

This policy establishes mandatory requirements for the retention and secure disposal of Company A data. The policy ensures that:

- Data is retained only as long as necessary for business, legal, regulatory, and historical purposes
- Storage costs are minimized by timely disposal of unnecessary data
- Legal liability is reduced by avoiding retention of data beyond required periods
- Privacy obligations are met by disposing of personal data when no longer needed
- Regulatory compliance is maintained across all applicable laws

1.2 Scope

This policy applies to:

- All data created, received, or maintained by Company A
- All data formats: electronic, paper, microfilm, audio/video
- All storage locations: on-premises, cloud, backup media, archives
- All departments and business units
- Contractors and third parties handling Company A data

1.3 Exclusions

This policy does not apply to:

- Data subject to active litigation hold (Section 4)
- Data required for ongoing regulatory investigations
- Data specifically exempted by executive management

1.4 Policy Principles

Principle	Description
Minimum Retention	Retain data only for the minimum period required
Maximum Destruction	Destroy data as soon as the retention period expires
Consistent Application	Apply retention schedules uniformly across the org
Secure Disposal	Ensure data is irrecoverable after destruction
Documentation	Maintain records of all destruction activities
Legal Hold Override	Suspend destruction for data under legal hold

1.5 Definitions

Term	Definition
Retention Period	The length of time data must be kept before disposal
Trigger Event	The event that starts the retention period clock
Litigation Hold	Legal instruction to preserve data potentially relevant
Certificate of Destruction	Formal documentation confirming data disposal
Custodian	Individual responsible for data in a specific system

2. LEGAL & REGULATORY BASIS

2.1 Applicable Saudi Regulations

2.1.1 Commercial Books Law (Royal Decree M/61)

Requirement	Detail
Financial Records	10 years minimum
Commercial Books	10 years from last entry
Contracts	10 years from expiration
Correspondence	5 years minimum

2.1.2 Labor Law (Royal Decree M/51)

Requirement	Detail
Employment Contracts	Duration + 5 years
Payroll Records	10 years
Disciplinary Records	5 years after termination
Work Injury Records	10 years

2.1.3 Personal Data Protection Law (PDPL)

Article	Requirement
Article 18	Data must not be retained longer than necessary fo
Article 19	Data must be destroyed or anonymized after retenti
Article 20	Data subject can request deletion when purpose ful

2.1.4 Anti-Money Laundering Law

Requirement	Detail
Transaction Records	10 years from transaction date
Customer Identity Records	10 years from relationship end
Suspicious Activity Reports	10 years from filing

2.2 Healthcare-Specific Regulations

2.2.1 CBAHI Standards

Record Type	Retention Period
Patient Medical Records	Patient lifetime + 10 years
Pediatric Records	Age 18 + 10 years
Surgical Records	Patient lifetime + 10 years
Radiology Images	10 years minimum

2.2.2 Ministry of Health Circulars

Circular	Requirement
----------	-------------

MOH 2022/31	Electronic health records preservation
MOH 2023/15	Telemedicine consultation records
MOH 2024/08	Clinical trial documentation

2.3 NDMO Requirements

Domain	Control	Requirement
Domain 4	DOP-RET-01	Documented retention schedule
Domain 4	DOP-RET-02	Automated retention enforcement
Domain 4	DOP-RET-03	Secure disposal procedures
Domain 4	DOP-RET-04	Destruction certification

2.4 International Standards

Standard	Relevance
ISO 15489	Records management best practices
ISO 27001 A.8.10	Secure disposal of information
NIST SP 800-88	Media sanitization guidelines

3. RETENTION SCHEDULE (DETAILED)

3.1 Financial Records

Record Type	Retention Period	Trigger Event	Legal Basis	System
General Ledger	10 years	Fiscal year end	Commercial Books Law	Oracle EBS
Accounts Payable Invoices	10 years	Payment date	Commercial Books Law	Oracle EBS
Accounts Receivable Invoices	10 years	Invoice date	Commercial Books Law	Oracle EBS
Bank Statements	10 years	Statement date	Commercial Books Law	Oracle EBS
Tax Returns (VAT)	10 years	Filing date	ZATCA	Oracle EBS
Tax Returns (Zakat)	10 years	Filing date	ZATCA	Oracle EBS
Budgets	5 years	Budget cycle end	Internal policy	SharePoint

Purchase Orders	10 years	PO date	Commercial Books Law	Oracle EBS
Contracts (Vendor)	10 years	Contract expiration	Commercial Books Law	SharePoint
Expense Reports	7 years	Report date	Internal policy	Oracle EBS

3.2 Human Resources Records

Record Type	Retention Period	Trigger Event	Legal Basis	System
Employment Application	Rejected: 1 year; Hired: Employment + 10 years	Application date / Termination	Labor Law	Oracle HCM
Employment Contract	Employment + 10 years	Termination date	Labor Law	Oracle HCM
Payroll Records	10 years	Payment date	Labor Law	Oracle HCM
Performance Reviews	5 years	Review date	Internal policy	Oracle HCM
Disciplinary Actions	Employment + 5 years	Termination date	Labor Law	Oracle HCM
Training Records	Employment + 3 years	Termination date	Internal policy	Oracle HCM
Medical Leave Records	Employment + 3 years	Termination date	Labor Law	Oracle HCM
Work Injury Reports	10 years	Incident date	Labor Law	Oracle HCM
Exit Interviews	5 years	Interview date	Internal policy	Oracle HCM
Background Checks	Employment + 5 years	Termination date	Labor Law	Oracle HCM

3.3 Healthcare / Clinical Records

Record Type	Retention Period	Trigger Event	Legal Basis	System
Patient Medical Record	Lifetime + 10 years	Patient death or last encounter	CBAHI	Epic EHR
Pediatric Records	Age 18 + 10 years	Patient turns 18	CBAHI	Epic EHR
Surgical Records	Lifetime + 10 years	Patient death	CBAHI	Epic EHR
Radiology Images (DICOM)	10 years	Study date	CBAHI	Philips PACS
Laboratory Results	10 years	Result date	CBAHI	Sunquest LIS
Pathology Reports	Lifetime + 10 years	Report date	CBAHI	Epic EHR
Prescription Records	10 years	Prescription date	MOH	Epic EHR
Consent Forms	Lifetime + 10 years	Consent date	CBAHI	Epic EHR
Referral Letters	10 years	Referral date	Internal policy	Epic EHR
Telemedicine Recordings	7 years	Consultation date	MOH 2023/15	MS Teams

3.4 Legal and Compliance Records

Record Type	Retention Period	Trigger Event	Legal Basis	System
Contracts (Major)	10 years	Contract expiration	Commercial Books Law	SharePoint
Legal Opinions	Permanent	N/A	Internal policy	SharePoint
Litigation Files	Case close + 10 years	Final judgment	Legal requirement	SharePoint
Regulatory Filings	10 years	Filing date	Various	SharePoint
Board Minutes	Permanent	N/A	Corporate governance	SharePoint
Policies and Procedures	Superseded + 5 years	Replacement date	Internal policy	SharePoint
Audit Reports	10 years	Report date	NDMO	SharePoint
Compliance Certifications	Certification + 5 years	Expiration date	Various	SharePoint

3.5 IT and Security Records

Record Type	Retention Period	Trigger Event	Legal Basis	System
System Access Logs	7 years	Log date	NDMO	Splunk
Security Incident Reports	7 years	Incident date	NDMO	ServiceNow
Network Traffic Logs	90 days	Log date	Internal policy	Splunk
Email (General)	3 years	Receipt date	Internal policy	Exchange
Email (Legal/Executive)	7 years	Receipt date	Internal policy	Exchange
Backup Catalogs	Backup retention + 1 year	Backup expiration	Internal policy	Veeam
Change Requests	5 years	Implementation date	ITIL	ServiceNow
Disaster Recovery Tests	7 years	Test date	NDMO	SharePoint

3.6 Operational Records

Record Type	Retention Period	Trigger Event	Legal Basis	System
Physical Access Logs	12 months	Log date	Internal policy	Access Control
CCTV Footage	30 days	Recording date	Internal policy	Milestone
Visitor Logs	3 years	Visit date	Internal policy	Visitor Mgmt
Asset Inventory	Asset disposal + 3 years	Disposal date	Internal policy	ServiceNow
Maintenance Records	Asset disposal + 3 years	Disposal date	Internal policy	ServiceNow
Vendor Performance	Contract + 5 years	Contract end	Internal policy	SharePoint

3.7 Research Records

Record Type	Retention Period	Trigger Event	Legal Basis	System
Clinical Trial Data	15 years	Study completion	SFDA	Research DB
IRB Approvals	Study close + 10 years	Study completion	SFDA	SharePoint
Informed Consent (Research)	Study close + 10 years	Study completion	SFDA	Research DB
Research Protocols	Study close + 10 years	Study completion	SFDA	SharePoint
Adverse Event Reports	Study close + 15 years	Study completion	SFDA	Research DB

4. LITIGATION HOLD PROCEDURES

4.1 Overview

A litigation hold (also known as legal hold or preservation notice) is a directive to preserve all data and documents that may be relevant to pending or anticipated litigation, regulatory investigation, or audit.

4.2 Litigation Hold Triggers

Trigger Event	Action Required
Receipt of complaint or lawsuit	Immediate hold
Regulatory investigation notice	Immediate hold
Internal investigation initiated	Hold within 24 hours
Anticipated litigation	Hold upon legal advice
External audit notification	Hold as specified

4.3 Hold Initiation Process

Step 1: Legal Department identifies need for litigation hold

↓

Step 2: General Counsel authorizes hold

↓

Step 3: Legal issues Litigation Hold Notice (LHN)

↓

Step 4: LHN distributed to:

- IT Operations (system preservation)

- Data Custodians (departmental data)
 - Affected employees (personal custody)
- ↓
- Step 5: IT disables automated deletion for affected data
- ↓
- Step 6: Hold registered in Litigation Hold Register
- ↓
- Step 7: Acknowledgment collected from all custodians
- ↓
- Step 8: Periodic reminders issued (quarterly)

4.4 Litigation Hold Notice Contents

Element	Description
Hold ID	Unique identifier (LH-2024-XXX)
Matter Description	Brief description of legal matter
Preservation Scope	Data types, date ranges, custodians
Systems Affected	List of systems under hold
Custodian Instructions	Specific preservation requirements
Consequences	Penalties for non-compliance
Contact	Legal department contact for questions

4.5 Hold Scope Definition

Dimension	Specification
Temporal	Date range of potentially relevant data
Subject Matter	Topics, projects, or transactions
Custodians	Individuals whose data must be preserved
Systems	Databases, file shares, email, etc.
Data Types	Documents, emails, chat, recordings

4.6 Active Litigation Holds

Hold ID	Matter	Scope	Start Date	Status	Next Review
LH-2024-001	Insurance claim	Patient encounters 2023	Jan 15, 2024	Active	Apr 15, 2024

[illegible]

5.2 Digital Data Disposal Methods

5.2.1 Standard Deletion (PUBLIC Data Only)

Method	Description	Use Case
File Delete	Standard OS deletion	Non-sensitive public data
Database DELETE	SQL DELETE command	Non-sensitive records
Application Delete	Via application interface	User-initiated removal

Note: Standard deletion does NOT securely destroy data and is only appropriate for PUBLIC classification.

5.2.2 Secure Deletion (INTERNAL, CONFIDENTIAL, SECRET)

Method	Standard	Verification	Use Case
DoD 5220.22-M (3-pass)	3 overwrite passes	Software verification	HDD disposal
NIST SP 800-88 Clear	Single overwrite	Software verification	HDD reuse
NIST SP 800-88 Purge	Cryptographic or degauss	Lab verification	HDD/SSD end-of-life

Crypto-shredding	Delete encryption key	Key deletion log	Encrypted data
------------------	-----------------------	------------------	----------------

5.2.3 Database Record Disposal

Data Classification	Method	Verification
PUBLIC	Standard DELETE	Row count
INTERNAL	DELETE + vacuum/shrink	Storage reduction
CONFIDENTIAL	DELETE + data masking of audit	Audit log
SECRET	DELETE + log purge + space overwrite	Full verification

5.2.4 Cloud Data Disposal

Cloud Service	Method	Verification
AWS S3	Object deletion + lifecycle	CloudTrail log
Azure Blob	Soft delete + hard delete	Activity log
Microsoft 365	Retention policy expiration	Compliance center

5.3 Physical Media Disposal

5.3.1 Hard Disk Drives (HDD)

Method	Standard	Certificate	Use Case
Degaussing	NIST SP 800-88	Required	End-of-life
Shredding	DIN 66399 H-3	Required	End-of-life
Degauss + Shred	NIST + DIN	Required	CONFIDENTIAL+

5.3.2 Solid State Drives (SSD)

Method	Standard	Certificate	Use Case
Crypto-erase	IEEE 2883	Required	Reuse
Shredding	DIN 66399 E-3	Required	End-of-life

5.3.3 Magnetic Tape

Method	Standard	Certificate	Use Case
Degaussing	NIST SP 800-88	Required	Reuse
Incineration	DoD 5220.22-M	Required	End-of-life

5.3.4 Paper Documents

Classification	Method	Standard	Certificate
PUBLIC	Recycle bin	N/A	No
INTERNAL	Strip-cut shredding	DIN 66399 P-3	No
CONFIDENTIAL	Cross-cut shredding	DIN 66399 P-4	Recommended
SECRET	Micro-cut shredding	DIN 66399 P-6	Required

5.3.5 Optical Media (CD/DVD)

Method	Standard	Use Case
Shredding	DIN 66399 O-3	All classifications
Incineration	N/A	Large volumes

5.4 Disposal Vendors

Vendor	Service	Certification	Contract
Iron Mountain	On-site shredding (paper)	NAID AAA	2024-2027
Shred-it Saudi	On-site shredding (paper)	ISO 27001	2024-2026
Data Destruction KSA	Media destruction	NIST certified	2024-2025
Dell Asset Recovery	IT equipment disposal	R2 certified	2024-2026

5.5 Certificate of Destruction Requirements

Each disposal event must generate documentation containing:

Element	Description
Certificate ID	Unique identifier (COD-2024-XXXX)
Date of Destruction	Date and time of disposal

Description	Data/media description
Quantity	Volume (records, media count, weight)
Method	Disposal method used
Standard	Compliance standard followed
Witness	Internal witness name and signature
Vendor Rep	External vendor representative (if applicable)
Serial Numbers	For media: serial numbers of destroyed items

6. AUDIT & ENFORCEMENT

6.1 Compliance Monitoring

6.1.1 Automated Monitoring

System	Monitoring Method	Alert Threshold
Oracle EBS	Informatica ILM reports	Data past retention
Epic EHR	Epic retention module	Archive candidates
SharePoint	Microsoft Purview	Policy violations
Exchange	Retention tags	Exceeded retention

6.1.2 Manual Reviews

Review	Frequency	Scope	Responsibility
Retention schedule accuracy	Annually	All schedules	Legal + DMO
Destruction log audit	Quarterly	50 random samples	Internal Audit
Vendor certification audit	Annually	All vendors	Procurement
Legal hold compliance	Quarterly	Active holds	Legal

6.2 Annual Destruction Audit

6.2.1 Audit Procedure

Step 1: Select 50 random destruction certificates

↓

Step 2: Verify certificate completeness

↓

Step 3: Confirm data no longer exists:

- Database query for deleted records
- File system check for removed files
- Media inventory reconciliation

↓

Step 4: Verify vendor certificates on file

↓

Step 5: Document findings in audit report

↓

Step 6: Remediate any gaps identified

6.2.2 Audit Metrics

Metric	Target	2023 Actual
Certificate completeness	100%	98%
Data verified destroyed	100%	100%
Vendor certificates on file	100%	95%
Retention schedule compliance	95%	92%

6.3 Non-Compliance Consequences

Violation	First Occurrence	Repeat Occurrence
Failure to follow retention schedule	Written warning	Performance impact
Destruction without authorization	Disciplinary action	Termination consideration
Litigation hold violation	Disciplinary action	Legal liability
Falsifying destruction records	Termination	Legal action

6.4 Exception Process

Exception Type	Approval Authority	Maximum Duration
Extended retention (business need)	CDO	2 years
Extended retention (legal)	General Counsel	Until matter resolved
Early disposal	CDO + Legal	N/A

Method exception	Information Security	Per case
------------------	----------------------	----------

7. ROLES AND RESPONSIBILITIES

7.1 RACI Matrix

Activity	Data Owner	DMO	IT Ops	Legal	Internal Audit
Define retention periods	A	R	C	C	I
Implement retention automation	C	R	A	I	I
Execute data disposal	C	C	A	I	I
Issue litigation hold	I	I	C	A	I
Audit retention compliance	I	C	C	I	A
Maintain destruction records	C	A	R	I	C

R = Responsible, A = Accountable, C = Consulted, I = Informed

7.2 Key Contacts

Role	Name	Department	Responsibility
Chief Data Officer	Dr. Khalid Al-Otaibi	Executive	Policy approval
General Counsel	Dr. Abdullah Al-Rasheed	Legal	Legal holds, compliance
Data Governance Manager	Hassan Al-Ghamdi	DMO	Schedule maintenance
IT Operations Manager	Fahad Al-Dosari	IT	Disposal execution
Compliance Manager	Fatima Al-Harbi	Compliance	Audit coordination

APPENDIX A: RETENTION SCHEDULE QUICK REFERENCE

Category	Minimum Retention	Maximum Retention
Patient Medical Records	Lifetime + 10 years	Permanent (historical)
Financial Records	10 years	10 years

Employee Records	Employment + 10 years	Employment + 10 years
Contracts	Expiration + 10 years	Expiration + 10 years
Email (General)	3 years	7 years
Security Logs	7 years	7 years
CCTV Footage	30 days	90 days (incident)
Research Data	Study + 15 years	Permanent (significant)

APPENDIX B: CERTIFICATE OF DESTRUCTION TEMPLATE

CERTIFICATE OF DESTRUCTION

Certificate Number: COD-2024-_____

Organization: Company A - Saudi Healthcare Authority

DESTRUCTION DETAILS

Field	Value
Date of Destruction	_____
Time of Destruction	_____
Location	_____
Method Used	_____
Standard Applied	_____

DATA/MEDIA DESCRIPTION

Item	Description	Quantity	Serial Numbers
1			
2			
3			

VERIFICATION

Check	Status
Retention period expired	■ Yes
No active legal hold	■ Yes
Data Owner approval obtained	■ Yes
Destruction witnessed	■ Yes
Data verified irrecoverable	■ Yes

SIGNATURES

Role	Name	Signature	Date
Executor			
Witness			
Vendor Rep (if applicable)			

Document End

Legal Department & Data Management Office
Company A - Saudi Healthcare Authority
Email: dataretention@companya.gov.sa
Version 2.1 | July 2024